Alerte de sécurité : multiples vulnérabilités dans Citrix NetScaler ADC et Gateway - (Ouvre une nouvelle fenêtre) Pour en savoir plus

Masquer le message

Le cadre de certification de cybersécurité européen

Adopté par le Parlement européen le 12 mars puis par le Conseil de l'Union européenne le 17 avril 2019, le règlement européen *Cybersecurity Act* (UE 2019/881) a été publié le 7 juin 2019 et marque une véritable avancée pour l'autonomie stratégique européenne. Il poursuit un double objectif :

- Adoption d'un mandat permanent pour l'ENISA, l'Agence de l'Union européenne pour la cybersécurité, valorisant et développant son rôle de facilitateur des échanges entre les États membres.
- Définition d'un cadre de certification de cybersécurité pour harmoniser à l'échelle européenne les méthodes d'évaluation et les différents niveaux d'assurance de la certification, au sein duquel l'ENISA trouve toute sa place. Les certificats délivrés bénéficieront d'une reconnaissance mutuelle au sein de l'Union européenne (UE).

Le *Cybersecurity Act* est un acte juridique européen, de portée générale, obligatoire dans toutes ses dispositions. Les États membres sont donc tenus d'appliquer ces dernières telles qu'elles sont définies par le règlement.Il s'agit d'un règlement d'application directe. Les États membres doivent avoir mis leur organisation nationale en conformité avec les dispositions du règlement dans les deux années suivant sa publication.Les schémas de certification qui sont publiés par la Commission européenne sont d'application volontaire.

A qui s'adresse cette réglementation ?

Le règlement concerne les **fabricants et fournisseurs** de produits, services et processus des technologies de l'information et de la communication (TIC) pour leur donner un ensemble d'exigences de sécurité.Il concerne également les **organismes d'évaluation de la conformité** pour délivrer des certificats de cybersécurité européens en utilisant des méthodes d'évaluation robustes et harmonisées.Il concerne finalement les **utilisateurs finaux et donneurs d'ordre** afin de leur permettre d'utiliser et choisir des produits TIC, services TIC et processus TIC correspondant à leur besoin de sécurité.

Quelles sont ses principales dispositions ?

Les acteurs du Cybersecurity Act

Le cadre européen de certification de cybersécurité impliquera plusieurs acteurs dont le rôle est défini dans le règlement européen:

- Autorité Nationale de Certification de Cybersécurité (**ANCC / NCCA** en anglais) : chaque État membre désigne une autorité nationale en charge de la surveillance des schémas de certification européens. Sa mission est listée à l'article 58 du règlement.
- Groupe Européen Certification de Cybersécurité (**GECC / ECCG** en anglais) : il s'agit des représentants de chaque État Membre. Sa mission est définie à l'article 62 du règlement.
- Groupe des Parties Prenantes pour la Certification de Cybersécurité (**SCCG** en anglais) : il s'agit de la représentation du secteur privé, des organismes de normalisation, des organismes d'accréditation, des organismes d'évaluation de la conformité, de la CNIL et de ses homologues, des universités et des organisations de consommateurs. Sa mission est définie à l'article 22 du règlement.
- Organisme d'Evaluation de la Conformité (**OEC / CAB** en anglais) : il s'agit d'un organisme en charge de la certification et de l'évaluation. Sa mission est définie à l'article 60 du règlement. Il peut y avoir plusieurs CAB dans un État membre. Les organismes de certification doivent être accrédités selon le règlement (CE) n°765/2008.
- Organisme National d'Accréditation (**NAB** en anglais) : il s'agit de l'organisme d'accréditation qui est le COFRAC en France.

Les modalités d'adoption d'un schéma

Le règlement détaille les méthodes d'adoption pour les futurs schémas européens de certification.Cinq étapes principales sont nécessaires :

- Le **programme de travail glissant de l'Union** (*Union Rolling Work Programme* en anglais): la Commission européenne définit un programme de travail après avoir consulté les groupes ECCG et SCCG.
- La **requête** : la Commission européenne confie à l'ENISA la rédaction d'un schéma sur la base du programme de travail, ou exceptionnellement d'un besoin spécifique qui serait identifié par l'ECCG.
- La **rédaction** : l'ENISA prépare le schéma candidat en s'appuyant sur les États membres et des experts constitués en groupe de travail *ad hoc*.
- La **revue technique** : une fois rédigée, la proposition de schéma est transmise à l'ECCG qui peut rendre une opinion.
- La **validation** : le schéma est ensuite transmis à la Commission pour son adoption définitive sous la forme d'actes d'exécution.

Les niveaux d'assurance d'un schéma de certification

Chaque schéma définira un ou plusieurs niveaux d'assurance avec sa méthodologie d'évaluation associée.Le processus de certification ainsi que la méthodologie d'évaluation différeront en fonction du niveau d'assurance visé. Trois niveaux sont définis par le règlement :

- Niveau **élémentaire**
    - ce niveau cible typiquement des objets grand public (ex : Internet des objets – IOT) ;
    - ce niveau peut permettre l'auto-évaluation des produits par leur fabricant (émission d'une attestation de conformité) ;
- Niveau **substantiel** :
    - ce niveau cible le risque médian, qui peut par exemple intéresser les assureurs dans leur couverture du risque des services ;
    - ce niveau repose sur une évaluation de la conformité effectuée par un CAB avec l'émission d'un certificat ;
- Niveau **élevé** :
    - ce niveau cible les solutions pour lesquelles il existe un risque d'attaques impliquant des compétences ou des ressources « significatives »;
    - ce niveau ajoute au précédent l'obligation de faire effectuer, par un tiers de confiance compétent, des tests de pénétration ;
    - la certification est délivrée par une autorité nationale de certification de cybersécurité, qui

sera la garante notamment des compétences techniques nécessaires pour les tests de pénétration.

Le rôle de l'ANSSI ?

La supervision ANCC

L'ANSSI est l'Autorité Nationale de Certification de Cybersécurité (ANCC) dans le cadre du *Cybersecurity Act*. A ce titre, l'ANSSI est en charge de surveiller la bonne application des différents schémas de certification européens en France.

La certification ANCC

Pour le niveau d'assurance élevé, le Cybersecurity act impose à ce que les certificats soient émis par l'ANCC (ou par un CAB dans certains cas de délégation). L'ANSSI se prépare donc à être en charge de la certification de niveau d'assurance élevé, à l'image de ce qu'elle réalise déjà pour la certification de sécurité de premier niveau (CSPN)

Membre ECCG

L'ANSSI en tant qu'autorité compétente représente la France au niveau de l'ECCG.

Points de contact

Pour toute question relative au *Cybersecurity Act*, vous pouvez nous contacter en nous envoyant un email à l'adresse ***ancc@ssi.gouv.fr***.

Pour aller plus loin

Les actualités du Cybersecurity Act

Trois schémas sont en cours de préparation à ce jour :

- Le schéma **EUCS** (EU Cloud Services) est en cours de rédaction et sera un schéma de certification de service pour les solutions d'informatique en nuage (dont SecNumCloud est la base pour le niveau d'assurance Elevé).
- Le schéma **EU5G** est en cours de rédaction. La deuxième phase qui vient d'être lancée, a notamment pour but de mettre à niveau le schéma NESAS opéré par la GSMA pour le rendre compatible avec les exigences du Cybersecurity Act, et d'implémenter les processus nécessaires pour optimiser la certification des cartes de type eUICC selon le schéma EUCC.
- Le schéma **EUDI Wallet**, qui permettra de certifier des wallets au niveau européen, est en phase de développement.

Le schéma **EUCC** qui reprend les caractéristiques des schémas de certification nationaux rassemblés au sein de l'accord de reconnaissance mutuelle du SOG-IS, couvre la certification de sécurité de produits selon les Critères communs **a été adopté le 31/01/2024**.

Les références règlementaires

- Le *Cybersecurity Act* en francais : (Ouvre une nouvelle fenêtre) https://eur-lex.europa.eu/legal-content/fr/TXT/PDF/?uri=CELEX:32019R0881&from=EN
- Le *Cybersecurity Act* en anglais : (Ouvre une nouvelle fenêtre) https://eur-lex.europa.eu/legal-content/en/TXT/PDF/?uri=CELEX:32019R0881&from=EN
- EUCC en français : (Ouvre une nouvelle fenêtre) Règlement d'exécution (UE) 2024/482 de la

Commission du 31 janvier 2024 portant modalités d’application du règlement (UE) 2019/881 du Parlement européen et du Conseil en ce qui concerne l’adoption du schéma européen de certification de cybersécurité fondé sur des critères communs (EUCC) (et son 1er amendement : (Ouvre une nouvelle fenêtre) Règlement d’exécution (UE) 2024/3144 de la Commission du 18 décembre 2024 modifiant le règlement d’exécution (UE) 2024/482 en ce qui concerne les normes internationales applicables et rectifiant ledit règlement d’exécution)

- EUCC en anglais : (Ouvre une nouvelle fenêtre) Commission Implementing Regulation (EU) 2024/482 of 31 January 2024 laying down rules for the application of Regulation (EU) 2019/881 of the European Parliament and of the Council as regards the adoption of the European Common Criteria-based cybersecurity certification scheme (EUCC) (et son 1er amendement : (Ouvre une nouvelle fenêtre) Commission Implementing Regulation (EU) 2024/3144 of 18 December 2024 amending Implementing Regulation (EU) 2024/482 as regards applicable international standards and correcting that Implementing Regulation)

Suivez-nous sur les réseaux sociaux

- BlueSky
- Github
- X
- LinkedIn

république
française

- info.gouv.fr
- service-public.gouv.fr
- legifrance.gouv.fr
- data.gouv.fr

- Contact & accès
- Presse
- Mentions légales
- Accessibilité : non conforme
- Plan du site

Sauf mention explicite de propriété intellectuelle détenue par des tiers, les contenus de ce site sont proposés sous licence etalab-2.0 Ce site est fait avec Sites Conformes